

DOKUMENT 02

MARKT, WETTBEWERBER & DIFFERENZIERUNG

Öffentlich belegte Marktanalyse und strategische Positionierung für eine service-native Managed-ISMS-Plattform.

Arbeitsbezeichnung: ISMS Managed Service Platform

Dokumentstatus: Erstellt - Version 1.0

Stand der Recherche: 21. Juli 2026

Quellenbasis: öffentliche Herstellerseiten, Produktdokumentation und aktuelle Produktmeldungen

Zweck: Marktstruktur, Wettbewerbsprofil, White Space und differenzierende Produktentscheidungen

Wichtige Leseregel: Produktbehauptungen der Anbieter werden als öffentliche Selbstdarstellung behandelt. Relative Lücken sind Hypothesen gegenüber unserer Zielvision - keine unabhängigen Qualitätsurteile.

1. Dokumentauftrag, Methode und Aussagegrenzen

Marktfakten, strategische Interpretation und Produktentscheidungen werden sichtbar getrennt

Dokument 02 beschreibt die relevante Marktlandschaft, vergleicht direkte und angrenzende Anbieter und übersetzt die Ergebnisse in eine belastbare Differenzierungsstrategie. Der Vergleich ist nicht als Beschaffungsentscheidung gedacht, sondern als Product-Discovery-Grundlage für die spätere Funktions-, UX-, Service- und Architekturarbeit.

ENTSCHEIDUNG

Die Zielplattform soll nicht über maximale Featurebreite gewinnen. Sie soll die Lücke zwischen ISMS-Fachlichkeit, kontinuierlicher Cyber-Risiko-Intelligenz und skalierbarem Managed-Service-Betrieb schließen.

1.1 Rechercheprinzipien

- Primärquellen: offizielle Produktseiten, Helpcenter, Dokumentation, Entwicklerportale und aktuelle Herstellerveröffentlichungen;
- Stichtag: 21. Juli 2026; der dynamische Markt muss vor Pilot, Ausschreibung und Preisentscheidung aktualisiert werden;
- Faktenebene: nur öffentlich belegte Funktionen, Zielgruppen, Bereitstellungsmodelle und Partnerangebote;
- Interpretationsebene: relative Nähe zur Zielvision, strategische Lücken und Differenzierungshypothesen;
- Keine Nutzung nichtöffentlicher PwC-Daten, interner Preise, interner Templates oder vertraulicher Wettbewerbsinformationen.

1.2 Grenzen der Analyse

Die Analyse ersetzt keine Hands-on-Produkttests, Kundeninterviews, Referenzgespräche, RFP-Antworten, Vertragsprüfung oder technische Due Diligence. Herstellerangaben zu Einsparungen, ROI, Marktführerschaft und AI-Wirkung sind nicht unabhängig verifiziert und werden nicht als objektive Benchmarks übernommen.

ANNAHME

Die öffentlich sichtbare Produktpositionierung bildet die strategische Richtung der Anbieter hinreichend ab, um White Space und Prototyp-Differenzierung zu bestimmen.

2. Executive Summary

Die wichtigsten Erkenntnisse für Produktstrategie und Demo

Markt ist breit, aber fragmentiert

Enterprise-GRC, Compliance Automation, ISMS-Spezialisten, MSP-Plattformen und Cyber-Risk-Intelligence lösen jeweils Teilprobleme sehr gut.

6clicks ist der engste Direktvergleich

Hub-&-Spoke, Multi-Client-Steuerung, AI und Provider-Lizenzierung adressieren bereits den skalierbaren GRC-Servicebetrieb.

Servicebetrieb bleibt unvollständig gedacht

Öffentliche Produktbilder zeigen selten Ressourcen-, Reise-, Deliverable-, Profitabilitäts- und Servicekataloglogik als ein integriertes Operating Model.

Entscheidungs-UX ist der White Space

Zielnavigator, Morning Mission, Kausalität, Simulation und rollenbezogene Entscheidungen können aus verknüpften Daten einen echten Arbeitsnavigator machen.

KERNTHESIS

Der Markt bietet starke Systeme für GRC, Audit, Compliance Automation, BSI-Fachlichkeit, Quantifizierung oder Multi-Client-Verwaltung. Die Chance liegt in der bewussten Kombination: ein digitaler Unternehmenszwilling als gemeinsame Wahrheit, ein Decision Center als Nutzererlebnis und ein Managed-Service-Betriebssystem als Geschäftsmodell.

2.1 Fünf strategische Konsequenzen

- Nicht versuchen, ServiceNow, MetricStream oder Archer in der gesamten GRC-Breite zu überholen.
- 6clicks, Secureframe und Partnerprogramme von Vanta/Drata als ernsthafte Referenz für Multi-Client-Delivery behandeln.
- BSI IT-Grundschutz, digitale Souveränität und europäische Bereitstellungsoptionen als notwendige Marktanforderung einplanen, nicht als alleinige Differenzierung.
- Cyber-Risk-Quantifizierung, Exposure- und Threat Intelligence überwiegend integrieren oder partnern; die proprietäre Stärke liegt in Kontext, Entscheidung und Serviceausführung.
- Die Demo muss die Differenzierung als End-to-End-Erlebnis beweisen: Portfolio → Kunde → Ursache → Entscheidung → Managed Service → Report → messbare Wirkung.

3. Marktstruktur: fünf konvergierende Produktkategorien

ISO/IEC 27001 fordert ein an Organisation und Risiken angepasstes, fortlaufend verbessertes Managementsystem. Der Softwaremarkt nähert sich diesem Ziel aus unterschiedlichen Richtungen, aber selten aus einer integrierten Serviceperspektive. ^[S1]

Kat.	Kategorie	Beispiele	Primärer Wert	Strategische Beobachtung
A	Enterprise IRM/GRC	ServiceNow, OneTrust, Archer, MetricStream, AuditBoard, LogicGate	Breite Risiko-, Compliance-, Audit- und Workflow-Steuerung für komplexe Organisationen	Hohe Konfigurierbarkeit und Integrationsbreite; häufig schwergewichtig und single-enterprise-orientiert
B	Compliance Automation / Trust	Vanta, Drata, Secureframe, Hyperproof	Kontinuierliche Evidenz, Framework-Mapping, Audit Readiness, Trust Center und Fragebögen	Schneller Nutzen und starke Automation; häufig Compliance- und Assurance-zentriert
C	ISMS-/Europa-Spezialisten	HiScout, verinice, ISMS.online	ISO 27001, BSI IT-Grundschutz, Policies, Risiko, Audit und Nachweise	Hohe Fachnähe; service-native Portfolio- und Entscheidungslogik öffentlich weniger zentral
D	Service-Provider Enablement	6clicks, Secureframe, Partnerökosysteme von Vanta, Drata, ISMS.online	Multi-Client-Verwaltung, Partnerprogramme, wiederholbare Delivery	Nähert sich dem Zielprodukt am stärksten; operative Beratungs- und Wertlogik bleibt Differenzierungsraum
E	Cyber Risk Intelligence / Quantification	CyberSaint, SAFE, SecurityScorecard	Finanzielle Quantifizierung, Exposure, Threat Intelligence und Third-Party Signals	Starke Spezialintelligenz; kein vollständiges ISMS- oder Managed-Service-Betriebssystem

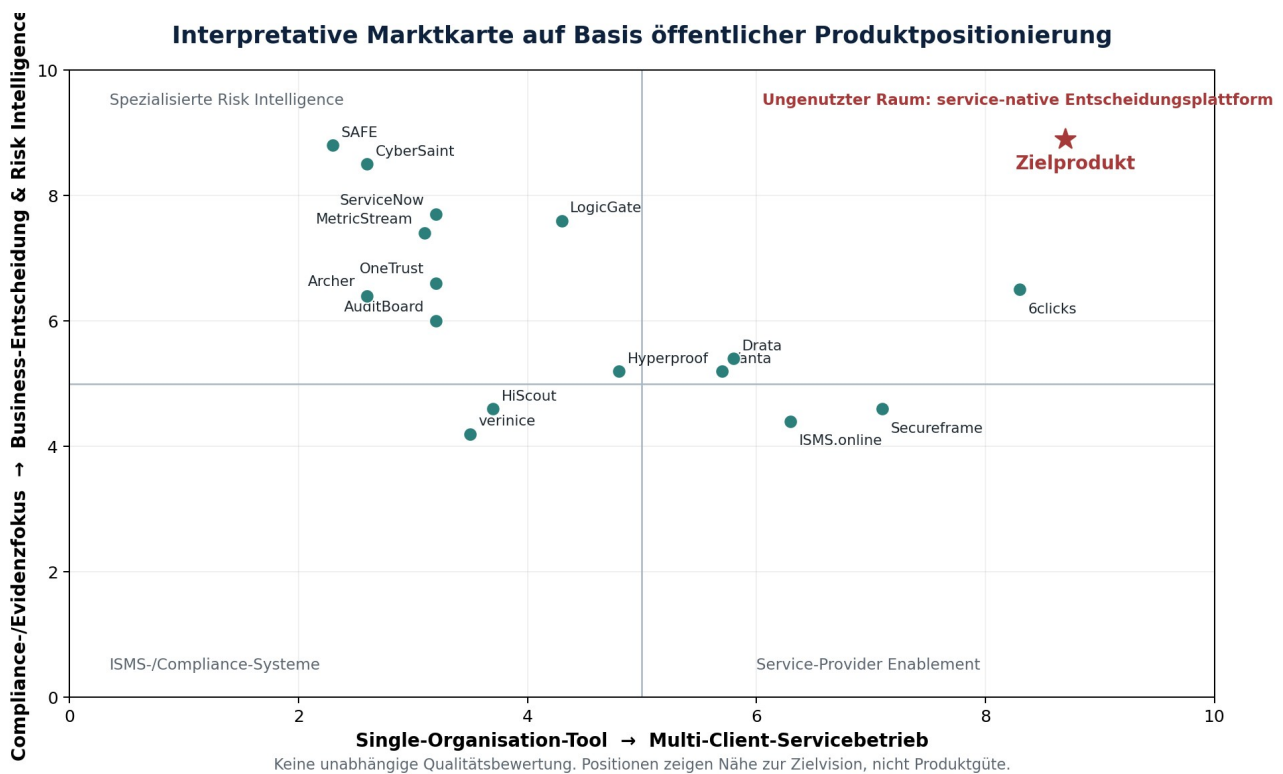


Abbildung 1 - Interpretative Marktkarte; Positionen beruhen auf öffentlicher Produktpositionierung und sind keine unabhängige Qualitätsbewertung.

3.1 Wettbewerbsbild nach Zielsegment

Zielsegment	Typische Wettbewerber	Kaufkriterien	Gewünschte Gegenposition
DACH Behörden / kritische Infrastruktur	HiScout, verinice, ServiceNow, 6clicks	BSI-Fachlichkeit, Souveränität, On-Premises, revisionssichere Zusammenarbeit	BSI + moderne Decision UX + service-native Portfolio-Steuerung
Regulierte Großunternehmen	ServiceNow, MetricStream, OneTrust, LogicGate, AuditBoard, Archer	Enterprise-Integration, breite GRC-Domänen, Governance und Auditierbarkeit	Schneller Time-to-Value, klarere UX und betrieberfähige Managed Services
Mittelstand / ISO / NIS2	Vanta, Drata, Secureframe,	Automatisierung, Guidance, Multi-	Tiefe ISMS-Navigation, Business-

Zielsegment	Typische Wettbewerber	Kaufkriterien	Gewünschte Gegenposition
	ISMS.online, Hyperproof	Framework und Audit Readiness	Risiko, Zielprofile und modulare Services
Beratungen / MSPs / vCISOs	6clicks, Secureframe, Vanta, Drata, ISMS.online, Hyperproof	Multi-Client-Zugang, Partnerprogramme, wiederholbare Compliance Delivery	End-to-End Servicebetrieb mit Kapazität, Reise, Deliverables, Profitabilität und Value Proof

4. Marktsignale 2026

Was sich sichtbar beschleunigt und was dadurch zur Baseline wird

Kontinuierliche statt periodischer Compliance: ServiceNow verbindet Risikomanagement und Vulnerability Response; Drata, Vanta, Secureframe und Hyperproof automatisieren Evidenz und Monitoring. Echtzeitnähe wird zur Erwartung, nicht zum Wow-Feature. ^[S2/S3/S13/S16/S17/S19/S21]

AI-Agenten werden in GRC-Workflows eingebettet: LogicGate veröffentlicht Workflow Agents und einen agentischen GRC Engineer; Vanta, Drata und andere positionieren Agenten als produktive Arbeitskräfte. AI allein differenziert deshalb kaum. ^[S8/S9/S13/S16]

Multi-Client- und Partnerbetrieb wächst: 6clicks ist explizit für MSPs und Advisors gebaut; Secureframe bietet eine Multi-Tenant-Plattform; Vanta, Drata, Hyperproof und ISMS.online bauen Servicepartner-Ökosysteme aus. ^[S11/S15/S18/S20/S22/S27]

Risk Quantification wird geschäftsorientierter: MetricStream, LogicGate, CyberSaint und SAFE übersetzen Cyberrisiko in finanzielle Wirkung, Investitionslogik und Managementsprache. Ein einfacher Heatmap-Score reicht strategisch nicht mehr. ^[S6/S8/S28/S29]

Souveränität und Bereitstellungswahl gewinnen Gewicht: 6clicks bewirbt sovereign cloud, self-hosted und Appliance; verinice bietet Cloud und on-premises sowie Open Source. Für Behörden und regulierte Märkte ist Deployment ein Kaufkriterium. ^[S12/S25]

Trust und Vertriebsunterstützung verschmelzen mit Compliance: Vanta, Drata und Secureframe verbinden Trust Center, Fragebogenautomation und Compliance-Nachweis. GRC wird nicht nur Kostenkontrolle, sondern unterstützt Umsatz und Kundenvertrauen. ^[S13/S16/S19]

4.1 Von Marktbaseline zu Differenzierung

Marktsignal	Erwartete Baseline	Differenzierende Antwort
Continuous Evidence	Automatische Tests, Evidence Collection und Statusaktualisierung	Nicht nur Control Health anzeigen, sondern Auswirkung auf Zielroute, Risiko und Servicearbeit erklären.
AI Agents	Entwürfe, Mapping, Evidence Review und Workflow Automation	AI-Ergebnis mit Confidence, Quellen, Human Approval und deterministischem Fallback verbinden.
Partnerprogramme	Partnerzugang, MSP-Directory und Delivery Support	Ein echtes Provider Operating Model mit Portfolio, Serviceobjekten, Kapazität, Qualität und Profitabilität bauen.
Risk Quantification	Finanzielle Verlustszenarien und Investitionssprache	Quantifizierung in konkrete Maßnahmen-, Budget- und Serviceentscheidungen übersetzen.
Souveränität	On-premises, sovereign cloud, self-hosted und offene Modelle	Deployment-Wahl, Datenresidenz, Exportierbarkeit und AI-Modellwahl als Architekturprinzip.
Trust & Assurance	Trust Center, Fragebogenautomation und Customer Assurance	Aus ISMS-Daten automatisch kunden- und vorstandsfähige Kommunikationsprodukte erzeugen.

SCHLUSSFOLGERUN G

Die Baseline des Zielprodukts muss Multi-Framework, API-fähig, kontinuierlich, rollenbasiert und AI-vorbereitet sein. Differenzierung entsteht erst oberhalb dieser Baseline: durch Decision-first UX, Servicebetrieb und nachvollziehbaren Wert.

5. Bewertungsmodell

Wie Anbieter fair gegen die Zielvision gespiegelt werden

Die folgende Bewertung ist kein Markt-Ranking. Sie misst, wie stark öffentlich belegte Produktpositionierung zu unserer spezifischen Zielvision passt. Ein niedriger Wert kann bedeuten, dass ein Anbieter bewusst einen anderen, erfolgreichen Schwerpunkt verfolgt.

ID	Kriterium	Was geprüft wird
K1	Enterprise-GRC-/ISMS-Tiefe	Risiken, Controls, Policies, Audit, Third Parties, Multi-Framework
K2	Kontinuierliche Daten & Evidenz	Integrationen, Tests, Monitoring, Datenherkunft
K3	Multi-Client-Servicebetrieb	isolierte Mandanten, zentrale Portfolio-Sicht, Partner-/MSP-Operating Model
K4	Decision Intelligence	Kausalität, Business Impact, Quantifizierung, Empfehlungen, Simulation
K5	Berater-Operations	Kapazität, Reisen, Vertretung, wiederverwendbare Arbeitspakete, Delivery-Steuerung
K6	Service-Kommerzialisierung	Servicekatalog, Buchung, SLA, Scope, Value Proof, Opportunity-Logik
K7	Executive & Deliverables	rollenbezogene Entscheidungen, Board Reporting, PDF/PPTX, Value Story
K8	Souveränität & Erweiterbarkeit	Cloud/on-prem, offene APIs, Datenresidenz, White Label, modulare Architektur

Legende der Capability-Matrix: H = stark öffentlich belegt; M = teilweise oder indirekt belegt; L = begrenzt belegt; - = in den ausgewerteten öffentlichen Quellen nicht nachgewiesen. Das Zeichen - bedeutet nicht, dass die Funktion sicher fehlt.

6. Direkte Wettbewerber für servicebasierte Compliance und ISMS

6.1 6clicks - engster strategischer Direktvergleich

6clicks positioniert Hub & Spoke ausdrücklich für Advisors und Managed Service Provider: zentrale Governance, isolierte Client-Spokes, zentralisierte Reports, vorkonfigurierte Inhalte, AI-Unterstützung und verschiedene souveräne Deployment-Optionen. Das ist der klarste öffentliche Beleg für ein GRC-Produkt, das Multi-Client-Service-Delivery als Kernarchitektur versteht. ^[S11/S12]

Stärken

Provider-native Architektur; Multi-Entity/Spoke-Isolation; Content-Verteilung; AI-Mapping; flexible Deployment-Modelle; channel-orientierte Lizenzierung.

Differenzierungsraum

Decision Center, kundenindividuelle Zielrouten, Beraterkapazität und Reisen, Serviceprofitabilität, Opportunity-Engine, Investitionssimulation und automatisch erzeugte Executive-Deliverables müssen tiefer und sichtbarer werden.

STRATEGISCHE BEDROHUNG

Hoch. 6clicks darf im Konzept nicht als Randanbieter behandelt werden. Der Prototyp muss innerhalb der ersten Minuten zeigen, warum er mehr ist als ein schöneres Hub-&-Spoke-GRC.

6.2 Secureframe - Compliance-as-a-Service mit Multi-Tenant-Betrieb

Secureframe bietet für MSPs, vCISOs und Berater eine Multi-Tenant-Plattform und verweist auf mehr als 150 Integrationen. Die Kernstärke liegt in automatisierter Compliance, Evidenz, Monitoring, Risk Management, Trust Center und service-provider-fähiger Delivery. ^[S19/S20]

Relative Lücke zur Zielvision: Die öffentliche Positionierung bleibt compliance- und auditgetrieben. Unser Zielprodukt muss breiter als Compliance Automation sein und Business-Ziele, ISMS-Betrieb, Serviceökonomie und Entscheidungswirkung verbinden.

6.3 Vanta - starke Trust-Plattform mit Agenten und Partnernetz

Vanta verbindet Compliance, Risk, Audit, Trust Center und Questionnaire Automation. Der Anbieter veröffentlicht klar abgestufte Produktpläne und betreibt ein MSP-Partnerprogramm. Die Stärke ist schnelle Automation und ein durchgängiges Trust-Narrativ. ^[S13/S14/S15]

Relative Lücke zur Zielvision: Die Plattform adressiert primär Trust- und Compliance-Programme. Differenzierung entsteht durch tiefe kundenindividuelle Zielnavigation, BSI-/ISMS-Kontext, Beratungsportfolio-Steuerung und die explizite Verbindung von Maßnahme, Service, Budget und Risikowirkung.

6.4 Drata - Agentic Trust Management und Continuous Compliance

Drata positioniert eine integrierte Plattform für Governance, internes und externes Risiko, kontinuierliche Compliance und Customer Assurance. MSSPs können als Guest Administrators arbeiten; Servicepartner liefern laufende Compliance- und Security-Leistungen. ^[S16/S17/S18]

Relative Lücke zur Zielvision: Partnerzugriff ist nicht automatisch ein vollständiges Provider Operating System. Unser Produkt muss Portfolio, Servicepakete, Kapazität, Termin- und Reiseplanung, Quality Gates und Wertnachweis als native Domäne abbilden.

6.5 ISMS.online und Hyperproof - strukturierte Compliance plus Partnerdelivery

ISMS.online verbindet Policies, Risiken, Controls, Assets, KPIs und Audit-Exporte und bietet MSPs strukturierte, wiederholbare Managed-Compliance-Services. Hyperproof vereint Compliance, Risk, Audit, Trust und Third-Party Risk und adressiert MSSPs im EMEA-Partnerprogramm. ^[S21/S22/S26/S27]

Relative Lücke zur Zielvision: Beide sind relevante Benchmarks für Nutzerfreundlichkeit und Partnerdelivery. Die Zielplattform muss sich durch Digital Twin, Decision-first UX, Berater-Operations und die tiefe Managed-Service-Wertschleife absetzen.

6.6 Benchmark: Service-Provider-Fähigkeit

Anbieter	Zentrale Konsole	Mandantentrennung	Partnerprogramm	Template-Verteilung	Portfolio-Reporting	Ressourcen/Reisen	Serviceökonomie
6clicks	H	H	H	H	H	M	M
Secureframe	H	H	H	M	M	L	M
Vanta	M	M	H	M	M	L	M
Drata	M	M	H	M	M	L	M
ISMS.online	M	M	H	M	M	L	M
Hyperproof	M	M	H	M	M	L	M
Zielprodukt	H	H	H	H	H	H	H

Die Matrix zeigt den eigentlichen Differenzierungsauftrag: Viele Anbieter unterstützen Partner und mehrere Kunden. Öffentlich kaum sichtbar ist jedoch ein durchgehendes Modell für Beraterkapazität, Reisen, Servicekosten, Quality Gates, Opportunity-Logik und Value Proof.

6.7 Fragen für spätere Hands-on-Demos

- Kann ein Serviceanbieter Standards, Workflows und Reports zentral ändern und kontrolliert an Kundeninstanzen verteilen?
- Sind Kundendaten technisch isoliert und können Berater nur auf aktive Engagements zugreifen?
- Gibt es portfolio-weite Priorisierung über Kunden, Risiken, Fristen und SLAs?
- Können Servicepakete, Scope, Verantwortungen und wiederkehrende Deliverables nativ modelliert werden?
- Werden Beraterkapazität, Reisezeit, Vertretung und Quality Review berücksichtigt?
- Kann der wirtschaftliche Wert eines Managed Service aus realen Plattformdaten nachgewiesen werden?

7. Enterprise-GRC- und IRM-Plattformen

Breite, Integrationskraft und Konfigurierbarkeit - aber selten service-native

Anbieter	Öffentlich belegter Schwerpunkt	Was übernommen werden sollte	Bewusste Gegenposition	Quelle
ServiceNow	Einheitliche Risiko-/Compliance-Plattform, Workflows, Audit, TPRM, Verbindung zu SecOps und Vulnerability Response.	Enterprise-Integration, Datenmodell, Workflow-Orchestrierung, kontinuierliche Risikosignale.	Nicht gegen Plattformbreite antreten; schnellerer Time-to-Value, Provider-Native UX und Servicebetrieb als Gegenposition.	S2/S3
OneTrust	GRC/Trust mit starker TPRM-, Datenschutz- und Reporting-Ausrichtung.	Third-Party Lifecycle, rollenbezogene Dashboards, brandbare PDF-Reports, Trust-Kontext.	ISMS-/Servicebetrieb und Decision Center als eigener Fokus.	S4
LogicGate	No-code GRC, Graph-Datenbank, Workflow Automation, Quantifizierung, API und Workflow Agents.	Moderne UX, flexible Datenmodelle, AI-Orchestrierung, Quantifizierung, Value Tracking.	Sehr starker funktionaler Benchmark; Differenzierung über Multi-Client-Delivery, Beraterbetrieb und Zielnavigation.	S8/S9/S10
MetricStream	Breites Enterprise GRC mit Cyber Risk, Quantifizierung, Threat-/Security-Integrationen und AI.	Tiefe für komplexe Organisationen, Business-Kontext, Quantifizierung und regulatorische Inhalte.	Leichter, klarer, service-native und schneller einsetzbar; keine Feature-Parität anstreben.	S6
Archer	Konfigurierbare IRM-Plattform für mehrere Risikodimensionen und Third-Party Ecosystem.	Bewährte Enterprise-Risk-Struktur, Verantwortlichkeit und Anpassbarkeit.	Modernere Entscheidungs-UX, Guided Journeys und Managed-Service-Layer.	S5
AuditBoard	Connected Risk für Audit, ERM, Compliance, IT Risk und Third-Party Risk.	Audit-/Assurance-Kollaboration, modernes Risiko-Narrativ, Stakeholder-Einbindung.	ISMS-Digital-Twin, Provider-Portfolio und Serviceökonomie vertiefen.	S7

LEARN, DO NOT COPY

Von Enterprise-GRC werden Datenmodell, Workflow-Orchestrierung, APIs, Auditierbarkeit und konfigurierbare Taxonomien übernommen. Nicht übernommen werden lange Implementierungsprojekte, überladene Navigation und eine Produktlogik, die den Nutzer mit Datenobjekten statt Entscheidungen konfrontiert.

8. Deutsche und europäische ISMS-Spezialisten

8.1 HiScout

HiScout positioniert eine gemeinsame GRC-Datenplattform mit Modulen für IT-Grundschutz, ISM, BCM, Datenschutz und Auditmanagement. Dezentrale Questionnaire-Technologie, individuelle Workflows und Behördennähe sind wichtige Benchmarks. Der zentrale Dienst ZeDIS zeigt die Eignung für zentral bereitgestellte Grundschutz-Services in der Bundesverwaltung. ^[S23/S24]

8.2 verinice

verinice kombiniert ISO 27001, BSI IT-Grundschutz, NIS2, TISAX, Datenschutz und BCM mit Open-Source- und Souveränitätspositionierung. Cloud- und On-Premises-Modelle sowie lizenzierte Grundschutzzinhalte sind für den deutschsprachigen Markt hochrelevant. ^[S25]

8.3 Strategische Konsequenz

Fachliche BSI-Abdeckung und Datenresidenz dürfen nicht als spätere Randfunktion geplant werden. Gleichzeitig ist die Zielplattform nicht erfolgreich, wenn sie lediglich eine modernere Grundschutz-Datenbank wird. Der Mehrwert muss oberhalb der Standards liegen: verknüpfte Business-Kontexte, Zielnavigation, Wirkungssimulation, Portfolio-Steuerung und Managed-Service-Ausführung.

RECHT & CONTENT

Geschützte Standards, Normtexte und lizenzierte BSI-/ISO-Inhalte dürfen nicht kopiert werden. Das Produkt benötigt eine Content-Lizenzierungs- und Mapping-Strategie; die Architektur muss eigene, lizenzierte und kundenspezifische Framework-Inhalte sauber trennen.

9. Angrenzende Spezialplattformen als Integrations- und Ideenquellen

Anbieter	Spezialisierung	Produktidee für Integration	Quelle
CyberSaint	Verknüpft Compliance-/Control-Posture mit finanzieller Cyber-Risikoquantifizierung und Executive-Kommunikation.	Business Impact, defensible models, Risiko- und Investitionssprache.	S28
SAFE	Automatisiert FAIR, misst Kontrollwirkung, Materialität und Kosten-Nutzen von Security-Investitionen.	Quantifizierungsmodell, ROI-/Budgetsimulation, Materiality.	S29
SecurityScorecard	Kontinuierliche externe Signale, Threat-informed TPRM, Ratings und Vendor Monitoring.	Threat-/Third-Party-Feeds, Trigger und externe Validierung.	S30

ENTSCHEIDUNG: Die Zielplattform baut keinen eigenen Schwachstellenscanner, kein globales Security-Rating-Netz und kein vollständiges FAIR-Datenökosystem. Sie wird Integrations-, Normalisierungs- und Entscheidungsplattform für solche Signale.

10. Capability-Matrix gegen die Zielvision

Öffentlich belegte Nähe - kein allgemeines Qualitätsranking

Anbieter	GRC/ISMS	Cont. Evidence	Multi-Client	Decision Intel.	Berater Ops	Service Layer	Exec./Reports	Souveränität
6clicks	H	M	H	M	M	M	M	H
Secureframe	M	H	H	L	L	M	M	L
Vanta	M	H	M	M	L	M	H	L
Drata	M	H	M	M	L	M	H	L
ISMS.online	H	M	M	L	L	M	M	L
Hyperproof	H	H	M	M	L	L	M	M
ServiceNow	H	H	L	H	L	L	H	H
LogicGate	H	H	L	H	L	L	H	M
MetricStream	H	H	L	H	L	L	H	H
OneTrust	H	H	L	M	L	L	H	M
AuditBoard	H	M	L	M	L	L	H	M
Archer	H	M	L	M	L	L	M	H
HiScout	H	M	L	L	L	L	M	H
verinice	H	M	L	L	L	L	M	H
Zielprodukt	H	H	H	H	H	H	H	H

Interpretation: Kein betrachteter Anbieter ist öffentlich in allen Zielkriterien stark positioniert. 6clicks kommt der Provider-Architektur am nächsten; ServiceNow, LogicGate und MetricStream setzen den Maßstab für Enterprise-Orchestrierung und Decision Intelligence; Vanta, Drata, Secureframe und Hyperproof für Continuous Compliance; HiScout und verinice für BSI-/Souveränitätsnähe.

11. White Space: unterversorgte Nutzeraufgaben

White Space	Zu lösender Job
Service-Portfolio statt Mandantenliste	Welche Kunden benötigen heute Aufmerksamkeit, welche Leistung ist fällig, wo droht SLA-/Qualitätsrisiko und wo entsteht Nachfrage?
Strategie-DNA und Zielnavigator	Nicht jeder Kunde will sofort Zertifizierung. Ziel, Risikobereitschaft, Budget, Eigenleistung und Managed-Service-Anteil müssen die Route bestimmen.
Kausalität statt Score	Warum verändert sich der Zustand? Welche Assets, Prozesse, Controls, Bedrohungen, Datenlücken und Entscheidungen erzeugen den Effekt?

White Space	Zu lösender Job
Wirkungsoptimierte Tagesmission	Welche drei Handlungen erzeugen heute die größte Ziel-, Risiko- und Servicewirkung unter realer Kapazität?
Beraterrealität	Reisezeit, Vor-Ort-Audits, Vertretung, Skills, Auslastung, wiederverwendbare Arbeitspakete und Mandantenwechsel gehören in das System.
Serviceentscheidung im Kontext	Interne Umsetzung, Beratungshilfe und Managed Service werden transparent mit Scope, Kostenband, Wirkung und Verantwortung verglichen.
Executive-Simulation	Was verändert eine Investition, Verschiebung oder Servicebuchung an Risiko, Zielzeit, interner Kapazität und erwarteter Verlustwirkung?
Communication Factory	Aus demselben Datenmodell entstehen Board-PPTX, CISO-Report, Audit-Pack, Workshop-Unterlage und Service-Review statt manueller Folienarbeit.
Value Proof	Das System zeigt nicht nur Aktivität, sondern eingesparte Zeit, vermiedene Doppelarbeit, geschlossene Datenlücken, Risikowirkung und Zielbeschleunigung.
Explainable AI und Confidence	Empfehlungen zeigen Datenbasis, Unsicherheit, Datenlücken und menschliche Freigabe; der Kern funktioniert auch ohne generative KI.

Differenzierungs-Stack: nicht ein weiteres GRC-Tool, sondern ein Service-Betriebssystem



Abbildung 2 - Differenzierung entsteht als gestapeltes Betriebssystem, nicht als einzelnes AI- oder Dashboard-Feature.

11.1 Sechs marktprägende Nutzungsmomente

Die Differenzierung muss in konkreten Arbeitssituationen sichtbar werden. Die folgenden Nutzungsmomente übersetzen den White Space in überprüfbare Produktreaktionen und wirtschaftlichen Nutzen.

Moment	Heutige Reibung	Zielreaktion der Plattform	Geschäftlicher Effekt
Portfolio-Morgen	Berater verteilt Aufmerksamkeit über viele Mandanten anhand von E-Mail, Kalender und Einzeltools.	Morning Mission priorisiert Veränderungen, Fristen, Reisebedarf, Datenqualität und Servicewirkung über das gesamte Portfolio.	Mehr betreubare Mandanten, weniger Such- und Koordinationszeit.
Management-Entscheidung	Ein hoher Score erklärt weder Ursache noch die beste Investitionsoption.	Decision Center zeigt Ursache-Wirkungs-Kette, Datenvertrauen und drei vergleichbare Handlungsrouten.	Schnellere Freigaben und nachvollziehbare Budgetentscheidungen.
Zieländerung	Framework-Checklisten bleiben statisch, obwohl Budget, Risikobereitschaft oder regulatorisches Ziel wechseln.	Strategie-DNA berechnet Zielroute, Prioritäten und Services neu und dokumentiert den Entscheidungsgrund.	Weniger Blindleistung und höhere Passung zum Kundenbedarf.
Neue Bedrohung	Threat- oder Scannerbefunde bleiben in Spezialtools und lösen manuelle Übersetzungsarbeit aus.	Der Unternehmenswilling mappt betroffene Prozesse, Assets, Controls, Risiken und mögliche Maßnahmen.	Kürzere Zeit von Signal zu belastbarer Entscheidung.
Servicegespräch	Zusätzliche Leistungen werden losgelöst von Risikowirkung und interner Alternative angeboten.	Die Opportunity Engine vergleicht Eigenleistung, Beratung und Managed Service mit Scope, Wirkung, Verantwortung und Kostenband.	Vertrauenswürdiger Ausbau wiederkehrender Services.
Vorstand oder Audit	Berater und CISO bauen Berichte wiederholt manuell aus verschiedenen Datenständen.	Communication Factory erzeugt adressatengerechte PPTX-, PDF- und Audit-Pakete mit Herkunft, Stichtag und Freigabestatus.	Weniger Aufbereitungszeit, konsistentere Aussagen und höhere Nachweisqualität.

12. Differenzierungsstrategie

Zehn verbindliche Säulen für Produkt, Demo und spätere Marktpositionierung

D1 - SERVICE-NATIVE ARCHITEKTUR	Multi-Tenancy ist nur die Basis. Services, Scopes, SLAs, Arbeitspakete, Quality Gates, Kapazität und Value Proof sind eigene Kernobjekte.
D2 - DIGITALER UNTERNEHMENSWILLING	Geschäftsprozesse, Organisation, Assets, Risiken, Controls, Maßnahmen, Nachweise, Audits und Services sind in einem nachvollziehbaren Graph verbunden.
D3 - DECISION-FIRST UX	Jede Hauptseite beantwortet eine Frage. Startpunkt sind Veränderungen, Ursachen, Entscheidungen und Wirkung - nicht Register und Tabellen.
D4 - KUNDENINDIVIDUELLE ZIELNAVIGATION	Zertifizierung, Reifegrad, regulatorisches Mindestniveau, Budget, Risikobereitschaft und Managed-Service-Anteil bilden eine Strategie-DNA.
D5 - MORNING MISSION UND PORTFOLIO INTELLIGENCE	Berater und Kunden erhalten eine priorisierte, kapazitätsrealistische Tagesmission über alle relevanten Mandanten und Aufgaben.
D6 - EXPLAINABLE RISK-TO-ACTION	Jede Empfehlung verbindet Risiko, Business Impact, Control, Maßnahme, Owner, Evidenz, Datenqualität und erwartete Wirkung.
D7 - MANAGED-SERVICE OPPORTUNITY ENGINE	Servicevorschläge entstehen aus belegten Kapazitäts-, Risiko-, Qualitäts- oder Fristmustern und zeigen immer auch die interne Alternative.
D8 - SIMULATION UND VALUE STORY	Budget-, Zeit-, Service- und Maßnahmenoptionen werden auf Zielerreichung, Risiko, Kapazität und Kostenwirkung gespiegelt.
D9 - DELIVERABLES ON DEMAND	PPTX, PDF, Audit-Pack und Workshop-Unterlagen werden rollen- und markenkonform aus dem aktuellen Datenstand erzeugt.
D10 - SOVEREIGN, API-FIRST, AI-OPTIONAL	Offene Integration, Deployment-Wahl und kontrollierte AI-Nutzung schaffen Vertrauen und vermeiden Technologieabhängigkeit.

13. Build, Integrate, License, Partner

Wo eigene Produktintelligenz entstehen muss und wo Spezialisierung sinnvoller ist

Modus	Gegenstände	Begründung
Selbst bauen	Decision Center, Strategie-DNA, Zielrouten, Serviceobjekte, Berater-Operations, Opportunity-Logik, Report/PPTX-Engine, Value Proof	Das ist der eigentliche Differenzierungs- und IP-Kern.
Integrieren	SIEM, CMDB, Ticketing, Cloud, IdP, Scanner, HR, Dokumente, Threat/Exposure Feeds	Doppelte Datenpflege vermeiden; vorhandene Systeme bleiben Systems of Record.
Lizenzieren	ISO-/BSI-/Brancheninhalte, regulatorische Bibliotheken, Benchmarkdaten	Urheberrecht, Aktualität und fachliche Qualität werden professionell abgesichert.
Partnern	Auditoren, Zertifizierer, Threat-Intelligence-, Rating- und CRQ-Anbieter	Netzwerkeffekte und Spezialdaten ohne eigenes Nachbauen.
Nicht bauen	SIEM, Vulnerability Scanner, globales Security Rating, vollständiges ERP/PSA, Zertifizierungsstelle	Fokus und Integrität der Produktkategorie erhalten.

14. Wettbewerbsspezifische Win Themes

Vergleich	Win Theme	Demo-Beweis
Gegen 6clicks	Nicht nur viele Kunden verwalten, sondern Beratungsarbeit, Entscheidung und Wert über den gesamten Lifecycle steuern.	Portfolio-Morning-Mission → Reise-/Kapazitätskonflikt → Serviceempfehlung → Board-PPTX → Value Proof.
Gegen ServiceNow / MetricStream / Archer	Schneller verständlich, service-native, geringere Einführungsbarriere und konsequent auf Informationssicherheitsarbeit zugeschnitten.	Ein Kunde wird in einer Minute verstanden; keine Konfigurationstiefe in der Demo zeigen.
Gegen Vanta / Drata / Secureframe	Mehr als Audit Readiness: kundenspezifischer Zielzustand, Cyber-Risiko-Kausalität und Managed-Service-Operating-Model.	Ziel Level 3 statt Zertifizierung → Route → Risikoereignis → neue Priorität.
Gegen HiScout / verinice	BSI-/ISO-Fachlichkeit plus moderne Decision UX, Integrationen, Multi-Client-Portfolio und Serviceökonomie.	Grundschutzobjekt → Business-Prozess → Wirkung → Beratermission.
Gegen SAFE / CyberSaint	Quantifizierung wird eingebettet, aber nicht zum isolierten Spezialtool. Das Ergebnis wird direkt in Maßnahmen, Service und Governance übersetzt.	Investment-Simulation → ausgewählte Maßnahme → Workflow → Report.

15. Was der Produktprototyp sichtbar beweisen muss

- Mehrere synthetische Kunden mit unterschiedlichen Zielfprofilen, Reifegraden, Branchen, Datenqualitäten und Servicepaketen;
- ein Berater-Portfolio mit Morning Mission, Kapazität, Auditterminen, Reisezeit, Eskalation und Opportunity;
- eine Kundendetailseite, die Strategie-DNA, Zustand, Veränderung, Ursache und größten Hebel in einer Minute erklärt;
- ein graphisch nachvollziehbarer Pfad von Bedrohung oder Schwachstelle über Asset, Prozess, Risiko, Control und Maßnahme;
- eine Was-wäre-wenn-Simulation für Budget, Maßnahme oder Managed Service;
- eine transparente Serviceempfehlung mit interner Alternative, Scope, Wirkung und Begründung;
- rollenbezogener Wechsel zwischen Executive, CISO/ISMS und Berater ohne Datenbruch;
- ein Klick zur Generierung eines Management-PDFs und einer bearbeitbaren PowerPoint;
- sichtbare Datenherkunft, Confidence und Datenlücken;
- messbarer Wert: Zeitersparnis, Zielbeschleunigung, Risikowirkung und Servicequalität.

DEMO-NORTH-STAR

Nach zehn Minuten soll ein Entscheider nicht sagen: „Das ist ein gutes ISMS-Tool“, sondern: „Damit können wir Informationssicherheits-Services anders verkaufen, liefern und skalieren.“

16. Strategische Risiken und Gegenmaßnahmen

ID	Risiko	Auswirkung	Gegenmaßnahme
R1	Feature-Überladung	Die Plattform versucht alle GRC-Kategorien zu ersetzen.	Klare Systems-of-Record-Grenzen; Differenzierungs-Stack priorisieren.
R2	6clicks wird unterschätzt	Provider-native Funktionen werden als neu behandelt, obwohl sie am Markt existieren.	Kontinuierlicher Battlecard-Vergleich und gezielte Demo-Differenzierung.
R3	AI wird zum Selbstzweck	Agenten erzeugen Show, aber keine verlässliche Wirkung.	AI-optional, Confidence, Approval, Audit Trail und deterministische Fallbacks.
R4	BSI-/Norminhalte werden rechtlich falsch behandelt	Geschützte Inhalte werden kopiert oder unklar lizenziert.	Content-Lizenzstrategie und Trennung von Modell, Mapping und Normtext.
R5	Quantifizierung wirkt scheinpräzise	Schwache Daten erzeugen überzeugende, aber unhaltbare Eurobeträge.	Bandbreiten, Szenarien, Datenqualität und Modellannahmen offenlegen.
R6	Berater werden überwacht statt unterstützt	Kapazitätsdaten werden zur individuellen Leistungskontrolle missbraucht.	Team-/Service-Optimierung, Transparenz, Zweckbindung und Governance.
R7	Demo verspricht technisch Unrealisierbares	Zu viele Live-Integrationen oder autonome AI-Funktionen.	Synthetische Daten und klar markierte Simulation; Architektur für spätere Integrationen.
R8	White Label verwässert Produktidentität	Jede Beratung konfiguriert ein anderes Produkt.	Konfigurierbares Branding bei verbindlichen Kernprinzipien und UX-Standards.

17. Validierungsplan

Was vor einer belastbaren Markt- oder Investitionsentscheidung noch geprüft werden muss

ID	Validierung	Ergebnis
V1	Hands-on Demos	6clicks, Secureframe, Vanta, Drata, ServiceNow, LogicGate, HiScout und verinice anhand derselben fünf Use Cases testen.
V2	Kundeninterviews	Mindestens 5 ISMS Manager, 5 Berater/Managed-Service-Leads und 3 Executives zu Frust, Entscheidungen und Zahlungsbereitschaft.
V3	Service Blueprint	Wiederkehrende Beratungsarbeit mit Zeit, Rollen, Übergaben, Reise, Qualität und Profitabilität empirisch erfassen.
V4	Content & Legal	ISO-/BSI-Lizenzierung, Audit-Unabhängigkeit, Datenschutz, Marken- und Report-Vorlagen klären.
V5	Pricing Discovery	Öffentliche Marktpreise, RFPs und Partnerkonditionen erheben; keine internen Preise erfinden.
V6	Technische Spike-Tests	Graphmodell, Multi-Tenancy, PPTX-Generierung, Integrationen und AI-Guardrails in kleinen Prototypen validieren.

18. Entscheidungen, Annahmen, offene Fragen und Ideenparkplatz

18.1 Globale Entscheidungen aus Dokument 02

- 02-D01 Die Plattform wird als service-native Entscheidungs- und Betriebsplattform positioniert, nicht als generisches GRC-Suite-Projekt.
- 02-D02 6clicks ist der engste direkte Wettbewerbsbenchmark und wird laufend beobachtet.
- 02-D03 Multi-Tenancy allein gilt nicht als Differenzierung; Serviceobjekte, Berater-Operations und Value Proof sind erforderlich.
- 02-D04 BSI-/ISO-Inhalte werden lizenziert oder verlinkt, nicht kopiert.
- 02-D05 Threat Intelligence, Scanner, Ratings und spezialisierte CRQ werden integriert oder gepartnert.
- 02-D06 Decision-first UX, Strategie-DNA und Zielnavigator bilden den primären Produktkern.
- 02-D07 AI ist Baseline-Unterstützung, aber kein alleiniger USP und keine Funktionsvoraussetzung.
- 02-D08 Souveräne Bereitstellungsoptionen und offene APIs werden architektonisch vorbereitet.
- 02-D09 Reporting umfasst PDF und bearbeitbare PPTX als operative Kernfunktion.
- 02-D10 Die Marktanalyse wird vor Pilot, Pricing und Beschaffung aktualisiert.

18.2 Annahmen

- Beratungen zahlen für messbar höhere Mandantenkapazität und konsistente Delivery.
- Kunden akzeptieren Serviceempfehlungen, wenn interne Alternative, Begründung und Datenlage transparent sind.
- Ein provider-natives Operating Model ist stärker differenzierend als ein weiterer Framework-Katalog.
- Executive-Simulation und automatisch erzeugte Deliverables erzeugen hohen Demo- und Alltagswert.
- Der deutschsprachige Markt belohnt BSI-Nähe, Datenresidenz und nachvollziehbare Governance.
- Die Zielplattform kann mit synthetischen Daten ein glaubwürdiges vollständiges Produktbild vermitteln.

18.3 Offene Fragen

- Welche Kundensegmente und Branchen sind der erste Beachhead?
- Welche BSI-/ISO-/Regulatory-Content-Lizenzen sind für einen kommerziellen Pilot nötig?
- Welche Provider-Funktionen bieten 6clicks, Secureframe und andere in nichtöffentlichen Enterprise-Paketen?
- Wie werden Beratung und unabhängige Assurance technisch und organisatorisch getrennt?
- Welche Quantifizierungsmethode ist für die erste Version verantwortbar?
- Welche Deployment-Variante ist für den ersten Prototyp und späteren Pilot verbindlich?
- Welche Servicepakete und Preisbänder werden in Dokument 14 mit Marktdaten validiert?
- Welche Integrationen müssen im Prototyp echt sein und welche dürfen simuliert werden?

18.4 Ideenparkplatz

- anonymisierte Benchmarking-Pools über Kundencluster;
- Marketplace für Branchenpakete, Workflows, Controls und Reportbausteine;
- Partnerzugang für Auditoren, Versicherer, Zertifizierer und Threat-Intel-Anbieter;
- Value-based Service Pricing auf Basis belegter Automatisierung und Zielbeschleunigung;
- digitale Service-Twins, die Abhängigkeiten, SLA, Upstream-Tools und Blast Radius darstellen;
- Executive Scenario Room für Krisen- und Investitionsentscheidungen.

19. Quellenregister

Öffentliche Primärquellen; Zugriff am 21. Juli 2026

Die Quellen dokumentieren öffentliche Produktpositionierung. Sie sind keine unabhängige Verifikation von Leistungsfähigkeit, Sicherheit, Preis oder Kundenerfolg.

- [S1] ISO - ISO/IEC 27001:2022 - Information security management systems: <https://www.iso.org/standard/27001>
- [S2] ServiceNow - Integrated Risk Management: <https://www.servicenow.com/products/integrated-risk-management.html>
- [S3] ServiceNow - Continuous monitoring for risks between Risk Management and Vulnerability Response: <https://www.servicenow.com/docs/r/governance-risk-compliance/grc-risk-management-workspace/continuous-monitoring-risk.html>
- [S4] OneTrust - Third-Party Risk Management: <https://www.onetrust.com/products/third-party-risk-management/>
- [S5] Archer - Archer GRC Solutions: <https://www.archerirm.com/solutions>
- [S6] MetricStream - IT and Cyber Risk Management: <https://www.metricstream.com/products/it-and-cyber-risk-management.htm>
- [S7] AuditBoard - IT Risk Management: <https://auditboard.com/itrm/>
- [S8] LogicGate - Risk Cloud Features: <https://www.logicgate.com/platform/features/>
- [S9] LogicGate - Spring 2026 Release and Workflow Agents: <https://www.logicgate.com/news/logicgate-solidifies-position-as-the-enterprise-ai-grc-leader-with-its-spring-2026-release/>
- [S10] LogicGate - Risk Cloud Developer Portal and API v2: <https://www.logicgate.com/developer/>
- [S11] 6clicks - Solutions for advisors and managed service providers: <https://www.6clicks.com/solutions/advisors-and-managed-service-providers>
- [S12] 6clicks - Plans and deployment options: <https://www.6clicks.com/plans>
- [S13] Vanta - Trust Management Platform: <https://www.vanta.com/>
- [S14] Vanta - Plans and Pricing: <https://www.vanta.com/pricing>
- [S15] Vanta - Managed Service Provider Partner Program: <https://www.vanta.com/downloads/msp>
- [S16] Drata - Agentic Trust Management Platform: <https://drata.com/products>
- [S17] Drata - Continuous Compliance: <https://drata.com/products/compliance>
- [S18] Drata - Working with an MSSP: <https://help.drata.com/en/articles/10771929-working-with-an-mssp-managed-security-service-provider>
- [S19] Secureframe - Compliance and Security Automation Platform: <https://secureframe.com/>
- [S20] Secureframe - Platform for Service Providers: <https://secureframe.com/partners/service-providers>
- [S21] Hyperproof - AI-Powered GRC Platform: <https://hyperproof.io/product/>
- [S22] Hyperproof - EMEA Partner Programme: <https://hyperproof.io/partners-emea/>
- [S23] HiScout - Integrated GRC platform for ISM, IT-Grundschutz, BCM and data protection: <https://www.hiscout.com/>
- [S24] HiScout - HiScout ISM: <https://www.hiscout.com/module/ism/>
- [S25] verinice - Open-source GRC, ISMS, DPMS and BCM platform: <https://verinice.com/en>
- [S26] ISMS.online - ISO 27001 Compliance Software: <https://www.isms.online/compliance-software/>
- [S27] ISMS.online - Partner programme for consultants and MSPs: <https://www.isms.online/partners/>
- [S28] CyberSaint - Cyber Risk Management and Quantification Platform: <https://www.cybersaint.io/>
- [S29] SAFE - FAIR-based cyber risk quantification: <https://safe.security/the-fair-standard/>
- [S30] SecurityScorecard - Threat-informed third-party risk platform: <https://securityscorecard.com/platform/>

20. Dokumentabhängigkeiten und nächste Schritte

Dokument 02 konkretisiert die strategische Positionierung aus Dokument 01 und nutzt das Rollenmodell aus Dokument 03. Es liefert Anforderungen an Dokument 05 (Produktlandkarte), 06 (UX/UI), 07 bis 10 (Digital Twin, Fachlogik und Decision Center), 13 bis 15 (Managed Services und Beraterbetrieb), 17 bis 20A (Integrationen, Architektur, Sicherheit und AI).

NÄCHSTER SCHRITT

Dokument 04 - Nutzerreisen und vollständiger Service-Lebenszyklus. Die Journeys müssen die in diesem Dokument definierten Win Themes und Demo-Beweise als zusammenhängende Nutzungserlebnisse operationalisieren.

Änderungsprotokoll: v1.0 - Erstfassung mit Marktstruktur, 16 Anbieterprofilen, Capability-Matrix, White Space, Differenzierungsentscheidungen und Validierungsplan. Stand 21.07.2026.